

## 9. LFI (Local File Inclusion)

LFI (Local File Inclusion) adalah kerentanan ketika aplikasi web memuat (include) file dari sistem berdasarkan input pengguna tanpa validasi yang memadai.

Dalam CTF dan Boot2Root, LFI sangat populer karena sering menjadi jalan untuk:

Membaca source code  
↓  
Membaca file konfigurasi  
↓  
Mendapat username/password  
↓  
Mendapat akses user  
↓  
Privilege Escalation  
↓  
Root

---

### Konsep Dasar

Misalkan developer membuat kode:

```
include($_GET['page']);
```

URL:

`http://target/index.php?page=home.php`

Normalnya:

home.php  
about.php  
contact.php

yang dimuat.

Masalah muncul jika input tidak dibatasi.

---

### Bagaimana Mengenali LFI

#### 1. Parameter yang Mencurigakan

Perhatikan URL seperti:

`?page=home`

`?file=report`

`?view=index`

`?template=main`

`?lang=en`

Parameter yang mengontrol file atau template sering menjadi kandidat LFI.

---

## 2. Struktur URL yang Menunjukkan Include

Contoh:

/index.php?page=home

/load.php?file=news

/render.php?template=default

Biasanya developer menggunakan parameter tersebut untuk memilih file yang akan ditampilkan.

---

## 3. Error yang Menarik

Misalnya ketika parameter diubah muncul:

Warning: include(...)

atau

Failed opening stream

atau

include(): failed to open

Pesan seperti ini sering menunjukkan aplikasi sedang mencoba membuka file.

---

## Enumerasi LFI

Saat menemukan parameter mencurigakan:

Catat:

Nama parameter  
Nilai normal  
Perubahan respons  
Pesan error

Contoh:

?page=home

menampilkan:

Welcome Home

Sedangkan:

?page=test

menampilkan:

File not found

Ini mengindikasikan parameter memang mengontrol file.

---

Apa yang Dicari Setelah Menemukan LFI

Dalam konteks CTF/lab, tujuan utamanya biasanya membaca file penting.

Target umum:

Konfigurasi aplikasi

config.php  
settings.php  
database.php  
.env

Sering berisi:

DB\_USER  
DB\_PASS

---

Informasi Sistem

/etc/passwd

Berguna untuk:

Mengetahui user  
Mengetahui shell  
Memetakan sistem

---

Source Code

Source code sering mengandung:

Password hardcoded  
API key  
Endpoint tersembunyi  
Logika aplikasi

---

Log

Kadang aplikasi menyimpan informasi sensitif dalam log:

access.log  
error.log

---

## Analisis Temuan

Setelah berhasil membaca file:

Tanyakan:

Apakah ada kredensial?

Contoh:

username=admin  
password=secret123

---

Apakah ada endpoint tersembunyi?

Contoh:

/admin  
/internal  
/debug

---

Apakah ada user lain?

Contoh:

john  
alice  
developer

---

Apakah ada SSH key?

Contoh:

id\_rsa  
authorized\_keys

Jika ditemukan, itu merupakan informasi sensitif yang harus dicatat dalam laporan.

---

Dampak LFI

LFI sering dianggap "hanya baca file".

Padahal dampaknya bisa besar:

Kebocoran source code

↓

Kebocoran konfigurasi

↓

Kebocoran password

↓

Kompromi akun

Karena itu LFI biasanya memiliki tingkat risiko tinggi.

---

#### Checklist Saat Menemukan LFI

Catat:

Parameter rentan

URL

Respons normal

Respons error

File yang dapat diakses

Data sensitif yang terekspos

Dampak terhadap sistem

---

#### Contoh Dokumentasi Laporan

##### Temuan

Parameter page menerima input yang digunakan untuk memuat file tanpa validasi yang memadai.

---

##### Bukti

/index.php?page=home

dan perubahan nilai parameter menyebabkan aplikasi mencoba membuka file lain.

---

##### Dampak

Penyerang dapat mengakses file lokal yang tidak seharusnya dapat dibaca.

##### Risiko:

- Kebocoran source code
- Kebocoran konfigurasi
- Kebocoran kredensial

- Informasi sistem

---

Mitigasi

Gunakan:

Whitelist file yang diperbolehkan

Contoh:

home  
about  
contact

bukan menerima nama file arbitrer dari pengguna.

Tambahan:

- Validasi input
- Hindari include langsung dari parameter
- Terapkan least privilege pada file sensitif
- Nonaktifkan pesan error detail di production

---

Pola Umum di Boot2Root

Banyak mesin mengikuti alur:

Nmap  
↓  
Web Enumeration  
↓  
Menemukan parameter page=  
↓  
LFI  
↓  
Membaca config.php  
↓  
Mendapat password database  
↓  
Login sebagai user  
↓  
Privilege Escalation  
↓  
Root

Karena itu, ketika menemukan parameter seperti:

page=  
file=  
view=  
template=  
lang=

anggap sebagai petunjuk kuat untuk melakukan analisis LFI lebih lanjut dalam lingkungan

CTF atau lab yang memang diizinkan.